NeuroVitality CRM Security Overview

Last Updated: 21 March 2026

At NeuroVitality CRM, we take the security of your data seriously. This document provides an overview of the security measures we have implemented to protect your information and ensure the integrity of our service. Our security program is aligned with industry best practices and standards such as SOC 2, GDPR, and ISO 27001.

Application Security

- **Secure Software Development Lifecycle (SDLC):** We integrate security into every phase of our development process, from design and coding to testing and deployment.
- **Vulnerability Management:** We conduct regular automated and manual security testing, including static and dynamic analysis, to identify and remediate vulnerabilities.
- **Input Validation:** All user input is strictly validated on both the client and server sides to prevent common injection attacks, including SQL injection and Cross-Site Scripting (XSS).
- **Content Security Policy (CSP):** We implement a strict CSP to prevent a wide range of content injection attacks.

Authentication and Access Control

- **Strong Password Policy:** We enforce a strong password policy requiring a minimum length and a mix of character types (uppercase, lowercase, numbers).
- **Two-Factor Authentication (2FA):** 2FA is mandatory for all user accounts, providing an essential second layer of security against unauthorized access.
- **Secure Session Management:** We use cryptographically signed, `httpOnly`, and `secure` cookies with a `sameSite=strict` policy to protect against session hijacking and Cross-Site Request Forgery (CSRF).

- **Role-Based Access Control (RBAC):** Access to data and features within the application is strictly controlled based on user roles and permissions, ensuring users can only access the information necessary for their work.

Data Encryption

- **Encryption in Transit:** All data transmitted between your browser and our servers is encrypted using industry-standard TLS 1.2 or higher.
- **Encryption at Rest:** All sensitive customer data, including contact information and credentials, is encrypted at rest in our database using AES-256-GCM encryption.

Infrastructure and Network Security

- **Cloud Infrastructure:** Our service is hosted on Railway, a secure and reliable cloud platform that is compliant with major security standards.
- **Firewalls and Network Isolation:** We utilize firewalls and network segmentation to protect our infrastructure from unauthorized access.
- **Rate Limiting:** We have implemented strict rate limiting on our API and authentication endpoints to protect against brute-force attacks and denial-of-service attempts.
- **HTTP Security Headers:** We enforce modern security headers, including HSTS (HTTP Strict Transport Security), to ensure secure connections and protect against protocol downgrade attacks.

Compliance and Data Protection

- **GDPR Compliant:** Our data handling practices are designed to comply with the General Data Protection Regulation (GDPR). We provide users with the rights to access, rectify, and erase their data.
- **Data Processing Agreement (DPA):** We offer a DPA to all customers, outlining our commitment and responsibilities as a data processor.

Incident Response

We have a formal incident response plan in place to promptly address and mitigate any security incidents. In the event of a data breach, we will notify affected customers without undue delay, in accordance with our legal and contractual obligations.

For more detailed information, please refer to our full Privacy Policy and Terms of Service. If you have any security-related questions or concerns, please contact us at security@neurovitalityltd.com.